

Fitness Platform - Full Fix & Security Plan

Phase 1: Stabilization

- Refactor project structure into /apps (web, api) and /packages (ui, utils, types)
- Remove tmp_deploy folders
- Setup environment configs (.env.local, .env.production, .env.staging)
- Add logging system (Winston/Pino)

Phase 2: Security

- Implement JWT with access + refresh tokens (httpOnly cookies)
- Backend role-based access control
- Rate limiting using Redis
- File upload validation (size, type)
- Add Helmet and proper CORS config

Phase 3: Wallet & Subscription

- Implement Ledger-based wallet (transactions table)
- Use atomic DB transactions
- Add idempotency keys
- Build subscription system with lifecycle (active, expired, trial, cancelled)
- Feature gating system based on plan
- Daily cron jobs for subscription checks
- Payment webhook placeholder (to be integrated later)

Phase 4: Performance

- Integrate Redis for caching, queues, sessions
- Convert AI system to async (queue + worker)
- Add caching for frequently accessed data
- Optimize database queries (indexes, pagination)

Phase 5: UX Improvements

- Smart onboarding by role
- Notification system (event-based)

- Auto-save forms
- Unified search system

Phase 6: Monitoring & DevOps

- Error tracking (Sentry)
- Metrics (Prometheus + Grafana)
- CI/CD pipeline (lint, build, test)
- Daily backups

Phase 7: Testing

- Unit tests (auth, wallet)
- Integration tests (subscriptions, payments)
- Load testing (AI, chat)

Execution Priority:

Week 1: Wallet, Auth, Security

Week 2: Subscription, Redis, AI async

Week 3: Performance, Monitoring, Testing